

Critical Review of the Campus Events & Clubs PRD

QUALITY ASSURANCE / SECURITY PERSPECTIVE | TEAM 12 | INDIVIDUAL ASSIGNMENT #1

Overall judgement: READY WITH CHANGES. The PRD has a credible security design, but release readiness depends on test evidence that the stated controls work under hostile, concurrent, and failure conditions.

Assessment

The PRD is stronger than a typical early MVP specification because it treats quality and security as backend and database responsibilities, not as frontend behavior. It clearly separates authentication from authorization, prevents the client from choosing a trusted role, requires ownership checks, keeps the Supabase service-role key server-side, and minimizes personal data. The active-only unique index, atomic registration rule, idempotent cancellation, consistent error shape, and explicit 401/403/409 behavior make the most important journeys testable. The limited two-role scope also reduces attack surface.

Material Gaps and Risks

- 1. Authentication assurance is incomplete.** The PRD says that Express verifies a Supabase token, but it does not define issuer, audience, signature, expiry, revocation, or clock-skew checks. It also leaves the trusted role source and role-change process open. These details affect account takeover and privilege-escalation risk.
- 2. Authorization needs a complete negative matrix.** Role and ownership rules are correct in principle, but every endpoint should be tested for unauthenticated access, wrong role, wrong owner, and identifier enumeration. If a service-role key bypasses Row Level Security, the API becomes a single critical enforcement point; database policies should still provide defense in depth.
- 3. Input and privacy requirements are too broad.** “Validate malicious input” is not measurable. The PRD should set field types and maximum lengths, reject unexpected properties and invalid state transitions, escape stored text to prevent XSS, and define retention/deletion rules for registration and log data. CORS rules, authentication-header logging, and rate limits for abusive requests are also unspecified.
- 4. Reliability claims require stronger evidence.** The duplicate-registration test is good, but registration must also race safely against an activity changing to CLOSED. Lost responses, repeated cancellation, database rollback, authentication outages, and Vercel cold starts must be tested against authoritative database state. NFR-02 should name the test load, environment, sample size, and measurement method.

Required Release Gate

Priority	Evidence required	Pass condition
Critical	AuthN/AuthZ integration tests	No role, ownership, or ID-enumeration bypass; no protected data returned
High	Concurrency and recovery tests	Exactly one active registration; CLOSED race, retry, cancellation, and rollback remain consistent
High	Secure-input and secret checks	Stored XSS is inert; schemas reject invalid input; repository/build/log scans expose no secrets or tokens
Medium	Production and NFR checks	HTTPS smoke test passes on Vercel; 95% latency target passes under a documented load

Conclusion

I recommend accepting the PRD as the implementation baseline, while keeping the status **READY WITH CHANGES**. No architectural redesign is necessary. Before release, the team must convert the remaining security statements into precise controls and demonstrate the release gate above with automated integration results, manual privacy/log review, and production smoke-test evidence. Documentation describes intent; QA evidence establishes trust.